

System Design -- Card Tokenization Service

Document Type: engineering | Design Doc: DD-2026-0072 | Status: Approved | Author: Sai Prasad Devarakonda

=====

1. Authors & Reviewers

Author: Sai Prasad Devarakonda -- sai.devarakonda@aexp.com -- (602) 555-0198

Reviewer (Security): Abhijeet Gandharwar -- abhijeet.gandharwar@aexp.com -- (212) 555-0115

Reviewer (Platform): Chris Patterson -- chris.patterson@aexp.com -- (480) 555-0181

This document describes the design of a service that replaces raw primary account numbers (PANs) with format-preserving tokens. Test PAN used in examples: 3782 822463 10005 (synthetic AmEx test number -- not a live card).

2. Token Generation & Vault

The service accepts a PAN, validates it against the issuer BIN range, and generates a surrogate token preserving the last four digits for display (e.g., token maps card 3782 822463 10005 to display value ****-****-*0005). Tokens are random, non-reversible without the vault, and stored in a partitioned key-value vault encrypted with envelope encryption (per-record data key wrapped by a KMS master key).

Detokenization requires a mutually authenticated mTLS call plus a scoped service identity; no batch detokenization is permitted.

3. Compliance & Throughput

The design keeps raw PANs out of all downstream analytics stores, narrowing PCI-DSS scope to the vault and tokenization service. Target throughput: 45,000 tokenizations/sec at p99 < 12ms. Keys rotate every 90 days with overlapping validity to avoid the propagation failure mode seen in INC-2026-0419. Security sign-off is required before any change to the detokenization path.